ReconLedger VAPT report

Unified VAPT report - AI-assisted, human-approved assessment of the authorised local lab

Report status: DRAFT - pending analyst review
Target: 127.0.0.1 ports 3000,4280 (localhost lab)
Started: 31 Oct 2026 16:14:37 IST
Finished: 31 Oct 2026 16:15:41 IST
Run time: 64.0 s

Prepared with ReconLedger by The Unique Trader Team. Lab-only: no third-party systems were tested.

1. Executive summary and scope

ReconLedger assessed 127.0.0.1 ports 3000,4280 (localhost lab) and recorded 30 findings (0 Critical, 3 High, 3 Medium, 3 Low, 21 Info). The highest-ranked issue is "Exposed directory /ftp/" on 127.0.0.1:3000 (High, 8.0/10). 3 findings were reported by more than one tool and merged; 19 tool hits were validated as likely false positives and down-ranked rather than hidden. No exploitation was performed. 3 of 3 active steps passed the human-approval gate (plan-file:Lab analyst (The Unique Trader Team)).

report status: DRAFT - pending analyst review

started: 31 Oct 2026 16:14:37 IST

finished: 31 Oct 2026 16:15:41 IST

run time: 64.0 s

target: 127.0.0.1 ports 3000,4280 (localhost lab)

scope allow-list: 127.0.0.0/8, ::1/128, localhost

active steps approved / asked: 3 / 3

executed: nmap_scan, header_check, nikto_scan

skipped (denied/no tool): none

blocked by scope guard: header_check -> http://example.com/

tool errors: none

findings: 30

2. Assessment methodology

Method (aligned to NIST SP 800-115)

1. Planning (NIST SP 800-115 S3): the analyst request is turned into an auditable plan; every target is checked against a loopback/private-only scope allow-list.
2. Discovery (S4): nmap TCP connect scan of the in-scope host and ports.
3. Vulnerability analysis (S4-5): for each open web port the agent plans an HTTP security-header check and a Nikto scan (safe tuning; no injection or DoS classes).
4. Validation: Nikto file/directory hits are re-fetched and compared with a random-path baseline (soft-404) to weed out false positives. No exploitation is attempted.
5. Correlation and ranking: duplicates merge across tools; findings on ports nmap confirmed open get context boosts; a JSON rules engine adjusts scores and records every reason.
6. Human review: every active step needs analyst approval before it runs; the report stays DRAFT until an analyst signs it off.

Rules of engagement

- Targets: only the organiser-authorised / local sandbox lab (loopback or private ranges). Public ranges and hostnames are refused at start-up and again inside each runner.
- Every active action (scan, HTTP probe) requires explicit human approval; denials are final for the run.
- No exploitation, brute force, injection payloads or denial-of-service checks.
- All decisions, approvals, blocks and errors are written to an append-only JSONL audit trail.

Assets tested

127.0.0.1 ports 3000,4280 (localhost lab); scope allow-list: 127.0.0.0/8, ::1/128, localhost

Tool execution summary

Time	Step	Target	Result
31 Oct 2026 16:14:37 IST	nmap_scan	127.0.0.1	ran, 1 raw findings
31 Oct 2026 16:14:37 IST	header_check	http://example.com/	blocked by scope guard

Time	Step	Target	Result
31 Oct 2026 16:14:37 IST	header_check	http://127.0.0.1:3000/	ran, 4 raw findings
31 Oct 2026 16:15:41 IST	nikto_scan	http://127.0.0.1:3000/	ran, 28 raw findings

Tool integration status (disclosed)

Tool	Status	Coverage	How
Nmap	live + import	network	runs `nmap -sT -Pn` against the lab; parses XML (`--format nmap-xml`)
Nikto	live + import	web	runs nikto.pl (safe tuning 0123b) against lab web ports; parses JSON (`--format nikto-json`); soft-404 validation
HTTP header check (built-in)	live	web	one GET per web port; CSP/HSTS/XFO/XCTO/Referrer/CORS/cookies/leaks
Generic JSON findings	import	any	`reconledger triage file.json`
OWASP ZAP	planned	web	not implemented
Nessus	planned	network	not implemented
OpenVAS / Greenbone	planned	network	not implemented
Burp Suite	planned	web	not implemented
Metasploit	planned (human-approved, lab-only)	exploitation	not implemented; ReconLedger performs no exploitation

3. Severity distribution and prioritised findings



ID	Severity	Score	Asset	Finding	Sources	Conf.
RL-001	High	8.0	127.0.0.1:3000	Exposed directory /ftp/	nikto	High
RL-002	High	7.5	127.0.0.1:3000	Missing Content-Security-Policy	headers+nikto	High
RL-003	High	7.0	127.0.0.1:3000	CORS allows any origin (Access-Control-Allow-Origin: *)	headers+nikto	High
RL-004	Medium	5.5	127.0.0.1:3000	Open port 3000/tcp (service guess: ppp)	nmap	High
RL-005	Medium	5.0	127.0.0.1:3000	Served over plain HTTP (no TLS)	headers	High
RL-006	Medium	4.0	127.0.0.1:3000	Missing Strict-Transport-Security	nikto	Medium
RL-007	Low	3.5	127.0.0.1:3000	Missing Referrer-Policy	headers+nikto	High
RL-008	Low	3.0	127.0.0.1:3000	robots.txt reveals path /ftp/	nikto	Medium
RL-009	Low	3.0	127.0.0.1:3000	Missing Permissions-Policy	nikto	Medium
RL-010	Info	0.9	127.0.0.1:3000	Nikto: contains 1 entry which should be manually viewed. (/robots.txt)	nikto	Medium
RL-011	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /.psql_history	nikto	Low
RL-012	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /.htpasswd	nikto	Low
RL-013	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /.bash_history	nikto	Low
RL-014	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /.mysql_history	nikto	Low
RL-015	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /.sh_history	nikto	Low
RL-016	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /.sqlite_history	nikto	Low
RL-017	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /userdata.json	nikto	Low
RL-018	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /login.json	nikto	Low
RL-019	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /master.json	nikto	Low
RL-020	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /masters.json	nikto	Low
RL-021	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /connections.json	nikto	Low
RL-022	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /connection.json	nikto	Low
RL-023	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /PasswordsData.json	nikto	Low
RL-024	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /users.json	nikto	Low
RL-025	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /conndb.json	nikto	Low

ID	Severity	Score	Asset	Finding	Sources	Conf.
RL-026	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /conn.json	nikto	Low
RL-027	Info	0.8	127.0.0.1:3000	Sensitive file reachable: /accounts.json	nikto	Low
RL-028	Info	0.7	127.0.0.1:3000	Exposed directory /public/	nikto	Low
RL-029	Info	0.7	127.0.0.1:3000	Known-vulnerable component signature: JAMon - Java Application Monitor Admin interface (/JAMonAdmin.jsp)	nikto	Low
RL-030	Info	0.6	127.0.0.1:3000	Uncommon response header: Uncommon header(s) 'x-recruiting'	nikto	Medium

4. Detailed vulnerability findings

RL-001 [High 8.0] Exposed directory /ftp/

Affected asset: 127.0.0.1:3000

Severity: High, score 8.0/10 (tool base 5.0; CVSS not computed)

CWE / OWASP: CWE-548 / A01:2021 Broken Access Control

Description: A directory path is served without authentication and may list its files.

Sources: nikto

Confidence: High (re-fetched and confirmed distinct content)

Validation status: confirmed: GET returned 200 with distinct content

Evidence: {"url": "/ftp/", "nikto_id": "001675", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "c1f93bece72035ad", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "confirmed: GET returned 200 with distinct content"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Exposed directory /ftp/ on 127.0.0.1:3000 is rated High (8.0/10): base 5.0 from the tool, adjusted by 3 rule(s). Backups, documents or config files in it can be downloaded by anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; validated-exposure: re-fetch confirmed real, distinct content at this path

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 5.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> validated-exposure: re-fetch confirmed real, distinct content at this path

Fix steps:

1. Disable directory listing.
2. Move sensitive files out of the web root.
3. Require authentication for the path if it must exist.

References: https://cwe.mitre.org/data/definitions/548.html

RL-002 [High 7.5] Missing Content-Security-Policy

Affected asset: 127.0.0.1:3000

Severity: High, score 7.5/10 (tool base 5.0; CVSS not computed)

CWE / OWASP: CWE-1021 / CWE-79 (defence in depth) / A05:2021 Security Misconfiguration

Description: The app sends no Content-Security-Policy, so the browser will run any script that ends up in a page.

Sources: headers+nikto

Confidence: High (independently reported by 2 tools: headers, nikto)

Validation status: observed; port confirmed reachable by nmap; not exploited (no active exploitation performed)

Evidence: {"url": "http://127.0.0.1:3000/", "also_reported_by": [{"source": "nikto", "id": "nikto-127.0.0.1:3000-013587-4", "url": "/", "nikto_msg": "Suggested security header missing: content-security-policy.", "references": ["https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP"]}]}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) looks like a web app; check its HTTP security headers

Explain why (score):

Summary: Missing Content-Security-Policy on 127.0.0.1:3000 is rated High (7.5/10): base 5.0 from the tool, adjusted by 3 rule(s). Any XSS bug becomes fully exploitable: session theft, account takeover, defacement.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: removes a browser defence, so any script-injection bug becomes directly exploitable.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; xss-surface: missing CSP leaves injected scripts unrestricted; multi-tool-agreement: two independent tools reported the same issue. Duplicate merged across headers+nikto

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 5.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> xss-surface: missing CSP leaves injected scripts unrestricted -> multi-tool-agreement: two independent tools reported the same issue

Fix steps:

1. Start with Content-Security-Policy: default-src 'self'; object-src 'none'; frame-ancestors 'none'.
2. Run it in Content-Security-Policy-Report-Only first and fix violations.
3. Remove inline scripts or move them behind nonces/hashes, then enforce.

References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy, https://owasp.org/Top10/A05_2021-Security_Misconfiguration/

RL-003 [High 7.0] CORS allows any origin (Access-Control-Allow-Origin: *)

Affected asset: 127.0.0.1:3000

Severity: High, score 7.0/10 (tool base 5.0; CVSS not computed)

CWE / OWASP: CWE-942 / A05:2021 Security Misconfiguration

Description: Access-Control-Allow-Origin: * lets any website read this app's responses from a visitor's browser.

Sources: headers+nikto

Confidence: High (independently reported by 2 tools: headers, nikto)

Validation status: observed; port confirmed reachable by nmap; not exploited (no active exploitation performed)

Evidence: {"url": "http://127.0.0.1:3000/", "value": "*", "also_reported_by": [{"source": "nikto", "id": "nikto-127.0.0.1:3000-000287-0", "url": "/", "nikto_msg": "Retrieved access-control-allow-origin header: *.", "references": []}]}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) looks like a web app; check its HTTP security headers

Explain why (score):

Summary: CORS allows any origin (Access-Control-Allow-Origin: *) on 127.0.0.1:3000 is rated High (7.0/10): base 5.0 from the tool, adjusted by 3 rule(s). Unauthenticated API data can be read cross-site; combined with token-in-header auth this widens data exposure.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: any website can read responses cross-origin without extra steps.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; cors-wide-open: any website can read responses from this app; multi-tool-agreement: two independent tools reported the same issue. Duplicate merged across headers+nikto

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 5.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> cors-wide-open: any website can read responses from this app -> multi-tool-agreement: two independent tools reported the same issue

Fix steps:

1. Replace * with an explicit allow-list of trusted origins.
2. Return Vary: Origin and never reflect arbitrary Origin values.
3. Keep credentialed endpoints off the wildcard entirely.

References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Access-Control-Allow-Origin

RL-004 [Medium 5.5] Open port 3000/tcp (service guess: ppp)

Affected asset: 127.0.0.1:3000

Severity: Medium, score 5.5/10 (tool base 3.0; CVSS not computed)

CWE / OWASP: CWE-200 (attack surface) / n/a (exposure)

Description: A TCP service accepts connections.

Sources: nmap

Confidence: High (directly observed in the live response / TCP handshake)

Validation status: observed by tool; not exploited (no active exploitation performed)

Evidence: {"port": 3000, "proto": "tcp", "service": "ppp", "product": "", "weaknesses_behind_port": 6}

Why the agent ran this step: discover which lab services listen on ports 3000,4280

Explain why (score):

Summary: Open port 3000/tcp (service guess: ppp) on 127.0.0.1:3000 is rated Medium (5.5/10): base 3.0 from the tool, adjusted by 2 rule(s). Every reachable service is attack surface; its risk depends on what runs behind it.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: the port fronts 6 weaknesses found by other tools.

Context: Correlation: 6 web weaknesses found behind this port. Rules applied: listening-service: service is listening and reachable; port-with-weaknesses: open port fronts an app with misconfigurations

Score trail: correlated: 6 web weaknesses found behind this port -> base severity 3.0 -> listening-service: service is listening and reachable -> port-with-weaknesses: open port fronts an app with misconfigurations

Fix steps:

1. Confirm the service is meant to be exposed.
2. Bind internal services to localhost or firewall them.
3. Fix the weaknesses found behind this port (see related findings).

References: https://nmap.org/book/man-port-scanning-basics.html

RL-005 [Medium 5.0] Served over plain HTTP (no TLS)

Affected asset: 127.0.0.1:3000

Severity: Medium, score 5.0/10 (tool base 4.0; CVSS not computed)

CWE / OWASP: CWE-319 / A02:2021 Cryptographic Failures

Description: The app is reachable over unencrypted HTTP.

Sources: headers

Confidence: High (directly observed in the live response / TCP handshake)

Validation status: observed; port confirmed reachable by nmap; not exploited (no active exploitation performed)

Evidence: {"url": "http://127.0.0.1:3000/"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) looks like a web app; check its HTTP security headers

Explain why (score):

Summary: Served over plain HTTP (no TLS) on 127.0.0.1:3000 is rated Medium (5.0/10): base 4.0 from the tool, adjusted by 1

rule(s). Credentials and session tokens can be read or modified by anyone on the network path.
Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.
Exploitability: needs a network-position attacker (same Wi-Fi / path).
Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable
Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 4.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable

Fix steps:

1. Terminate TLS (reverse proxy or app) with a valid certificate.
2. Redirect all HTTP requests to HTTPS.
3. Then enable HSTS.

References: https://owasp.org/Top10/A02_2021-Cryptographic_Failures/

RL-006 [Medium 4.0] Missing Strict-Transport-Security

Affected asset: 127.0.0.1:3000

Severity: Medium, score 4.0/10 (tool base 3.0; CVSS not computed)

CWE / OWASP: CWE-319 / A02:2021 Cryptographic Failures

Description: No HSTS header, so browsers will still try plain HTTP first.

Sources: nikto

Confidence: Medium (single signature-based scanner, not independently confirmed)

Validation status: observed; port confirmed reachable by nmap; not exploited (no active exploitation performed)

Evidence: {"url": "/", "nikto_id": "013587", "method": "GET", "nikto_msg": "Suggested security header missing: strict-transport-security.", "references": ["https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security"], "cve": []}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Missing Strict-Transport-Security on 127.0.0.1:3000 is rated Medium (4.0/10): base 3.0 from the tool, adjusted by 1 rule(s). Allows SSL-stripping on first visit once TLS exists.
Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.
Exploitability: needs a network-position attacker (same Wi-Fi / path).
Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable
Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 3.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable

Fix steps:

1. After TLS is in place, add Strict-Transport-Security: max-age=31536000; includeSubDomains.

References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security

RL-007 [Low 3.5] Missing Referrer-Policy

Affected asset: 127.0.0.1:3000

Severity: Low, score 3.5/10 (tool base 2.0; CVSS not computed)

CWE / OWASP: CWE-200 / A05:2021 Security Misconfiguration

Description: Full URLs may leak to third parties in the Referer header.

Sources: headers+nikto

Confidence: High (independently reported by 2 tools: headers, nikto)

Validation status: observed; port confirmed reachable by nmap; not exploited (no active exploitation performed)

Evidence: {"url": "http://127.0.0.1:3000/", "also_reported_by": [{"source": "nikto", "id": "nikto-127.0.0.1:3000-013587-5", "url":

"/", "nikto_msg": "Suggested security header missing: referrer-policy.", "references": ["https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy"]}]}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) looks like a web app; check its HTTP security headers

Explain why (score):

Summary: Missing Referrer-Policy on 127.0.0.1:3000 is rated Low (3.5/10): base 2.0 from the tool, adjusted by 2 rule(s). Tokens or IDs in URLs can leak to external sites.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: no specific exploitability signal; scored on base severity.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; multi-tool-agreement: two independent tools reported the same issue. Duplicate merged across headers+nikto

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 2.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> multi-tool-agreement: two independent tools reported the same issue

Fix steps:

1. Add Referrer-Policy: strict-origin-when-cross-origin.

References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy

RL-008 [Low 3.0] robots.txt reveals path /ftp/

Affected asset: 127.0.0.1:3000

Severity: Low, score 3.0/10 (tool base 2.0; CVSS not computed)

CWE / OWASP: CWE-200 / A05:2021 Security Misconfiguration

Description: robots.txt lists a path the owner may not want indexed.

Sources: nikto

Confidence: Medium (single signature-based scanner, not independently confirmed)

Validation status: observed; port confirmed reachable by nmap; not exploited (no active exploitation performed)

Evidence: {"url": "/ftp/", "nikto_id": "999997", "method": "GET", "nikto_msg": "/robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200).", "references": ["https://portswigger.net/kb/issues/00600600_robots-txt-file"], "cve": []}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: robots.txt reveals path /ftp/ on 127.0.0.1:3000 is rated Low (3.0/10): base 2.0 from the tool, adjusted by 1 rule(s). Low: it hints where interesting content lives.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: not exploitable on its own; aids reconnaissance.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 2.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable

Fix steps:

1. Protect the path with access control instead of relying on robots.txt.

RL-009 [Low 3.0] Missing Permissions-Policy

Affected asset: 127.0.0.1:3000

Severity: Low, score 3.0/10 (tool base 2.0; CVSS not computed)

CWE / OWASP: CWE-693 / A05:2021 Security Misconfiguration

Description: Browser features (camera, geolocation...) are not restricted.

Sources: nikto

Confidence: Medium (single signature-based scanner, not independently confirmed)

Validation status: observed; port confirmed reachable by nmap; not exploited (no active exploitation performed)

Evidence: {"url": "/", "nikto_id": "013587", "method": "GET", "nikto_msg": "Suggested security header missing: permissions-policy.", "references": ["https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy"], "cve": []}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Missing Permissions-Policy on 127.0.0.1:3000 is rated Low (3.0/10): base 2.0 from the tool, adjusted by 1 rule(s). Low direct impact; widens what injected script could use.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: no specific exploitability signal; scored on base severity.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 2.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable

Fix steps:

1. Add Permissions-Policy disabling unused features, e.g. camera=(), geolocation=().

References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy

RL-010 [Info 0.9] Nikto: contains 1 entry which should be manually viewed. (/robots.txt)

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.9/10 (tool base 2.0; CVSS not computed)

CWE / OWASP: CWE-200 / A05:2021 Security Misconfiguration

Description: robots.txt lists a path the owner may not want indexed.

Sources: nikto

Confidence: Medium (single signature-based scanner, not independently confirmed)

Validation status: observed; port confirmed reachable by nmap; not exploited (no active exploitation performed)

Evidence: {"url": "/robots.txt", "nikto_id": "999996", "method": "GET", "nikto_msg": "contains 1 entry which should be manually viewed.", "references": ["https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt"], "cve": []}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Nikto: contains 1 entry which should be manually viewed. (/robots.txt) on 127.0.0.1:3000 is rated Info (0.9/10): base 2.0 from the tool, adjusted by 2 rule(s). Low: it hints where interesting content lives.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: not exploitable on its own; aids reconnaissance.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; info-only: informational finding, low direct impact

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 2.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> info-only: informational finding, low direct impact

Fix steps:

1. Protect the path with access control instead of relying on robots.txt.

RL-011 [Info 0.8] Sensitive file reachable: /.psql_history

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/.psql_history", "nikto_id": "001535", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /.psql_history on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-012 [Info 0.8] Sensitive file reachable: /.htpasswd

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/.htpasswd", "nikto_id": "002739", "method": "GET", "nikto_msg": "Contains authorization information.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /.htpasswd on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3

rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-013 [Info 0.8] Sensitive file reachable: /.bash_history

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/.bash_history", "nikto_id": "002743", "method": "GET", "nikto_msg": "A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /.bash_history on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-014 [Info 0.8] Sensitive file reachable: /.mysql_history

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/.mysql_history", "nikto_id": "002748", "method": "GET", "nikto_msg": "Database SQL?.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /.mysql_history on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-015 [Info 0.8] Sensitive file reachable: /.sh_history

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/.sh_history", "nikto_id": "002756", "method": "GET", "nikto_msg": "A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /.sh_history on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-016 [Info 0.8] Sensitive file reachable: /.sqlite_history

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/.sqlite_history", "nikto_id": "007129", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /.sqlite_history on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-017 [Info 0.8] Sensitive file reachable: /userdata.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/userdata.json", "nikto_id": "007203", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /userdata.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-018 [Info 0.8] Sensitive file reachable: /login.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/login.json", "nikto_id": "007204", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /login.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world

exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-019 [Info 0.8] Sensitive file reachable: /master.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/master.json", "nikto_id": "007205", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /master.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-020 [Info 0.8] Sensitive file reachable: /masters.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/masters.json", "nikto_id": "007206", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /masters.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-021 [Info 0.8] Sensitive file reachable: /connections.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/connections.json", "nikto_id": "007207", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /connections.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world

exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-022 [Info 0.8] Sensitive file reachable: /connection.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/connection.json", "nikto_id": "007208", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /connection.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-023 [Info 0.8] Sensitive file reachable: /PasswordsData.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/PasswordsData.json", "nikto_id": "007210", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /PasswordsData.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-024 [Info 0.8] Sensitive file reachable: /users.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/users.json", "nikto_id": "007211", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /users.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world

exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-025 [Info 0.8] Sensitive file reachable: /conndb.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/conndb.json", "nikto_id": "007212", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /conndb.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-026 [Info 0.8] Sensitive file reachable: /conn.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/conn.json", "nikto_id": "007213", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /conn.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-027 [Info 0.8] Sensitive file reachable: /accounts.json

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.8/10 (tool base 6.0; CVSS not computed)

CWE / OWASP: CWE-538 / A01:2021 Broken Access Control

Description: A file name associated with secrets or history files answered with HTTP 200.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/accounts.json", "nikto_id": "007215", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Sensitive file reachable: /accounts.json on 127.0.0.1:3000 is rated Info (0.8/10): base 6.0 from the tool, adjusted by 3 rule(s). If real, credentials or internal data are exposed to anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world

exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 6.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Confirm whether the content is real (see validation status).
2. Remove the file from the web root or deny the path at the server.
3. Rotate any secret it contained.

References: https://cwe.mitre.org/data/definitions/538.html

RL-028 [Info 0.7] Exposed directory /public/

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.7/10 (tool base 5.0; CVSS not computed)

CWE / OWASP: CWE-548 / A01:2021 Broken Access Control

Description: A directory path is served without authentication and may list its files.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/public/", "nikto_id": "001811", "method": "GET", "nikto_msg": "This might be interesting.", "references": [], "cve": [], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Exposed directory /public/ on 127.0.0.1:3000 is rated Info (0.7/10): base 5.0 from the tool, adjusted by 3 rule(s). Backups, documents or config files in it can be downloaded by anyone.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: a plain GET is enough to retrieve it if real; validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; exposed-sensitive-path: path may expose data to unauthenticated users; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 5.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> exposed-sensitive-path: path may expose data to unauthenticated users -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Disable directory listing.
2. Move sensitive files out of the web root.
3. Require authentication for the path if it must exist.

References: https://cwe.mitre.org/data/definitions/548.html

RL-029 [Info 0.7] Known-vulnerable component signature: JAMon - Java Application Monitor Admin interface (/JAMonAdmin.jsp)

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.7/10 (tool base 5.0; CVSS not computed)

CWE / OWASP: CWE-1104 / CWE-1395 / A06:2021 Vulnerable and Outdated Components / CVE-2013-6235

Description: A scanner signature for a component with a published CVE matched this path.

Sources: nikto

Confidence: Low (validation shows a catch-all response; likely false positive)

Validation status: likely false positive: response is identical to the app's catch-all page for a random path

Evidence: {"url": "/JAMonAdmin.jsp", "nikto_id": "007303", "method": "GET", "nikto_msg": "JAMon - Java Application Monitor Admin interface identified. Versions 2.7 and earlier contain XSS vulnerabilities.", "references": ["CVE-2013-6235"], "cve": ["CVE-2013-6235"], "validated_status": 200, "body_sha256": "21cbe884eaf2c3b3", "soft404_baseline": "21cbe884eaf2c3b3", "validation": "likely false positive: response is identical to the app's catch-all page for a random path"}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Known-vulnerable component signature: JAMon - Java Application Monitor Admin interface (/JAMonAdmin.jsp) on 127.0.0.1:3000 is rated Info (0.7/10): base 5.0 from the tool, adjusted by 3 rule(s). If the component is really present, its published vulnerability (see CVE) applies.

Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.

Exploitability: matches a known-vulnerable signature (CVE-2013-6235); validation suggests the file is not really there.

Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; known-vulnerable: signature references a published CVE; likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 5.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> known-vulnerable: signature references a published CVE -> likely-false-positive: validation: same body as a random non-existent path (SPA catch-all), so likely not real

Fix steps:

1. Check the validation status: on single-page apps this is often a catch-all false positive.
2. If real, upgrade or remove the component.
3. Re-scan to confirm.

References: https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/

RL-030 [Info 0.6] Uncommon response header: Uncommon header(s) 'x-recruiting'

Affected asset: 127.0.0.1:3000

Severity: Info, score 0.6/10 (tool base 1.0; CVSS not computed)

CWE / OWASP: n/a / n/a

Description: Tool-reported observation.

Sources: nikto

Confidence: Medium (single signature-based scanner, not independently confirmed)

Validation status: observed; port confirmed reachable by nmap; not exploited (no active exploitation performed)

Evidence: {"url": "/", "nikto_id": "999100", "method": "GET", "nikto_msg": "Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.", "references": [], "cve": []}

Why the agent ran this step: Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then validate its hits against a soft-404 baseline

Explain why (score):

Summary: Uncommon response header: Uncommon header(s) 'x-recruiting' on 127.0.0.1:3000 is rated Info (0.6/10): base 1.0

from the tool, adjusted by 2 rule(s). Review manually.
Exposure: 127.0.0.1:3000 accepts TCP connections (confirmed by nmap in this run). Lab scope: loopback only, so real-world exposure depends on deployment.
Exploitability: not exploitable on its own; aids reconnaissance.
Context: Correlation: nmap confirms 127.0.0.1:3000 is open and reachable. Rules applied: confirmed-reachable: port scan confirms the weak service is actually reachable; info-only: informational finding, low direct impact
Score trail: correlated: nmap confirms 127.0.0.1:3000 is open and reachable -> base severity 1.0 -> confirmed-reachable: port scan confirms the weak service is actually reachable -> info-only: informational finding, low direct impact

Fix steps:

1. Review the evidence and decide whether action is needed.

5. Impact and remediation

ID	Finding	Business / technical impact	Remediation
RL-001	Exposed directory /ftp/	Backups, documents or config files in it can be downloaded by anyone.	Disable directory listing. Move sensitive files out of the web root. Require authentication for the path if it must exist.
RL-002	Missing Content-Security-Policy	Any XSS bug becomes fully exploitable: session theft, account takeover, defacement.	Start with Content-Security-Policy: default-src 'self'; object-src 'none'; frame-ancestors 'none'. Run it in Content-Security-Policy-Report-Only first and fix violations. Remove inline scripts or move them behind nonces/hashes, then enforce.
RL-003	CORS allows any origin (Access-Control-Allow-Origin: *)	Unauthenticated API data can be read cross-site; combined with token-in-header auth this widens data exposure.	Replace * with an explicit allow-list of trusted origins. Return Vary: Origin and never reflect arbitrary Origin values. Keep credentialed endpoints off the wildcard entirely.
RL-004	Open port 3000/tcp (service guess: ppp)	Every reachable service is attack surface; its risk depends on what runs behind it.	Confirm the service is meant to be exposed. Bind internal services to localhost or firewall them. Fix the weaknesses found behind this port (see related findings).
RL-005	Served over plain HTTP (no TLS)	Credentials and session tokens can be read or modified by anyone on the network path.	Terminate TLS (reverse proxy or app) with a valid certificate. Redirect all HTTP requests to HTTPS. Then enable HSTS.
RL-006	Missing Strict-Transport-Security	Allows SSL-stripping on first visit once TLS exists.	After TLS is in place, add Strict-Transport-Security: max-age=31536000; includeSubDomains.
RL-007	Missing Referrer-Policy	Tokens or IDs in URLs can leak to external sites.	Add Referrer-Policy: strict-origin-when-cross-origin.
RL-008	robots.txt reveals path /ftp/	Low: it hints where interesting content lives.	Protect the path with access control instead of relying on robots.txt.
RL-009	Missing Permissions-Policy	Low direct impact; widens what injected script could use.	Add Permissions-Policy disabling unused features, e.g. camera=(), geolocation=().
RL-010	Nikto: contains 1 entry which should be manually viewed. (/robots.txt)	Low: it hints where interesting content lives.	Protect the path with access control instead of relying on robots.txt.
RL-030	Uncommon response header: Uncommon header(s) 'x-recruiting'	Review manually.	Review the evidence and decide whether action is needed.

Findings validated as likely false positives (soft-404) are listed in sections 3-4 but excluded here.

6. Assessment limitations

- Testing limitations: unauthenticated, black-box checks only; no exploitation, credentialed scanning, fuzzing or business-logic testing. Nikto ran with safe tuning (0123b) and a time cap.
- Severity is a context-adjusted 0-10 score from tool base severity plus explicit rules; it is not a CVSS vector.
- Assumptions: the lab app on loopback stands in for the client asset; real exposure depends on how it is deployed.
- Integrations disclosed in section 2: Nmap, Nikto and the header check ran live; ZAP, Nessus, OpenVAS, Burp and

Metasploit are planned, not implemented.
- Scan failures: none
- Scope blocks: header_check -> http://example.com/
- Human approvals: nmap_scan -> 127.0.0.1: approved by plan-file:Lab analyst (The Unique Trader Team), header_check -> http://127.0.0.1:3000/: approved by plan-file:Lab analyst (The Unique Trader Team), nikto_scan -> http://127.0.0.1:3000/: approved by plan-file:Lab analyst (The Unique Trader Team)
- Assessment timestamps: started 31 Oct 2026 16:14:37 IST, finished 31 Oct 2026 16:15:41 IST (64.0 s).

Appendix A. Plan, approval and audit trail

Every planned step, scope decision, approval, execution and error from the append-only JSONL audit log.

Time	Event	Action	Target	Detail
31 Oct 2026 16:14:37 IST	run_start			initial=0
31 Oct 2026 16:14:37 IST	round			n=1; actions=['nmap_scan', 'header_check']
31 Oct 2026 16:14:37 IST	planned	nmap_scan	127.0.0.1	kind=active; reason=discover which lab services listen on ports 3000,4280
31 Oct 2026 16:14:37 IST	approval	nmap_scan	127.0.0.1	approved=True; by=plan-file:Lab analyst (The Unique Trader Team); risk_note=TCP connect scan; sends connection attempts to the lab host only
31 Oct 2026 16:14:37 IST	executed	nmap_scan	127.0.0.1	new_findings=1
31 Oct 2026 16:14:37 IST	planned	header_check	http://example.com/	kind=active; reason=operator-supplied extra target
31 Oct 2026 16:14:37 IST	blocked_scope	header_check	http://example.com/	error=target 'http://example.com/' is outside the lab scope
31 Oct 2026 16:14:37 IST	round			n=2; actions=['header_check', 'nikto_scan']
31 Oct 2026 16:14:37 IST	planned	header_check	http://127.0.0.1:3000/	kind=active; reason=Open port 3000/tcp (service guess: ppp) looks like a web app; check its HTTP security headers
31 Oct 2026 16:14:37 IST	approval	header_check	http://127.0.0.1:3000/	approved=True; by=plan-file:Lab analyst (The Unique Trader Team); risk_note=one HTTP GET to the lab app; no payloads
31 Oct 2026 16:14:37 IST	executed	header_check	http://127.0.0.1:3000/	new_findings=4
31 Oct 2026 16:14:37 IST	planned	nikto_scan	http://127.0.0.1:3000/	kind=active; reason=Open port 3000/tcp (service guess: ppp) is a web service; header checks only see one response, so run Nikto to look for exposed files, directories and known-bad components, then va
31 Oct 2026 16:14:37 IST	approval	nikto_scan	http://127.0.0.1:3000/	approved=True; by=plan-file:Lab analyst (The Unique Trader Team); risk_note=~5,000 HTTP requests to the lab app over up to 3 minutes; safe tuning 0123b (no injection or DoS checks)
31 Oct 2026 16:15:41 IST	executed	nikto_scan	http://127.0.0.1:3000/	new_findings=28
31 Oct 2026 16:15:41 IST	ranked			count=30; top=[('nikto-127.0.0.1:3000-001675-9', 8.0), ('hdr-127.0.0.1:3000-content-security-policy', 7.5), ('hdr-127.0.0.1:3000-cors-wildcard', 7.0), ('nmap-127.0.0.1-3000', 5.5), ('hdr-127.0.0.1:300

Analyst sign-off

DRAFT - pending analyst review